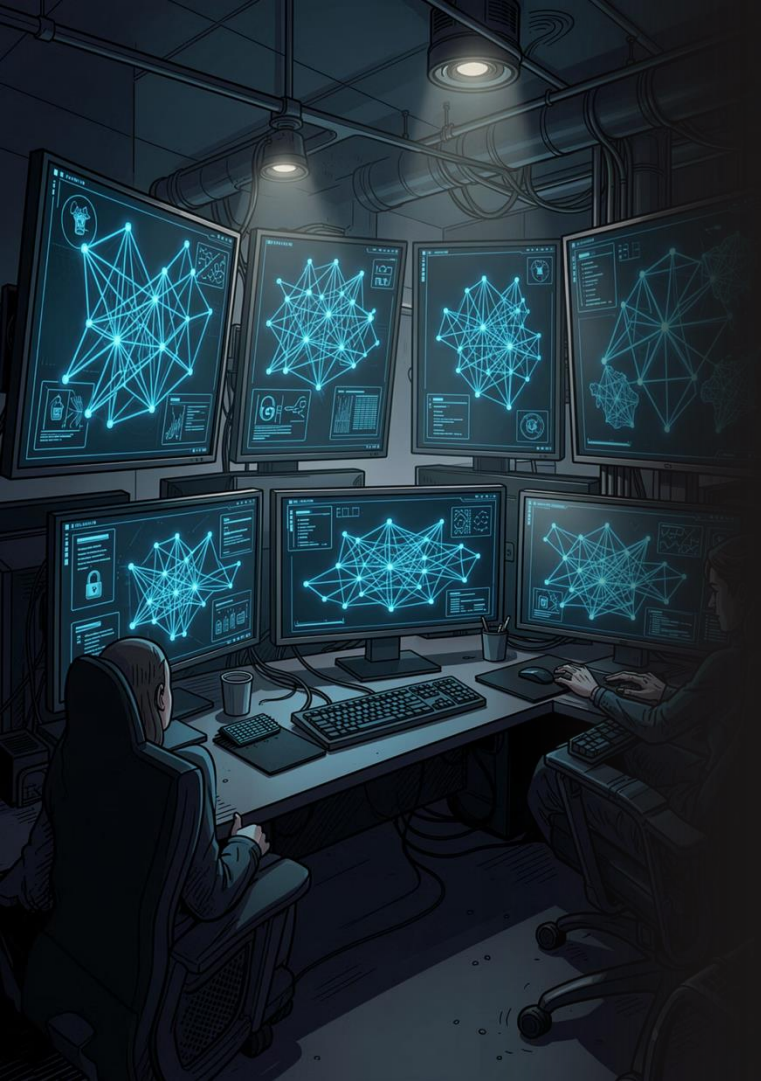




# Enterprise Security Guardrail Auditor

*Automated compliance enforcement and security posture validation at enterprise scale*

# The Compliance Gap Is Growing

## Manual Audits Don't Scale

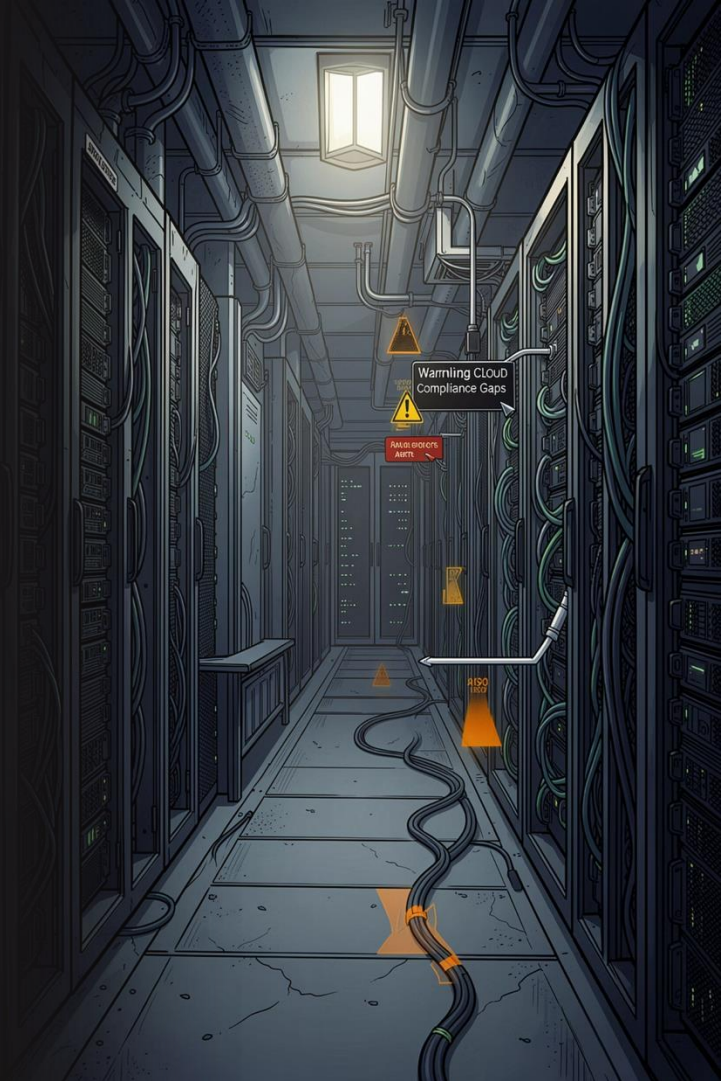
*Security reviews are periodic, inconsistent, and unable to keep pace with continuous cloud deployments across hundreds of accounts.*

## Regulatory Exposure

*Wolters Kluwer operates under strict mandates — GDPR, SOC 2, ISO 27001. A single misconfiguration can trigger audit failure and regulatory penalties.*

## Alert Fatigue

*Security teams are overwhelmed by raw scanner output with no prioritization, context, or automated remediation guidance.*



# System Architecture



## Design Principles

- **Agentless** — integrates directly with cloud provider APIs
- **Event-driven** — triggered on resource creation, modification, or scheduled scan
- **Extensible** — policy packs are modular and version-controlled
- **Audit-ready** — every finding is timestamped, attributed, and exportable

# Technology Stack



## Core Engine

*Python 3.11 · FastAPI · Celery · Redis (task queue)*



## Data Layer

*PostgreSQL (findings) · Elasticsearch (search) · S3 (report artifacts)*



## Security Integrations

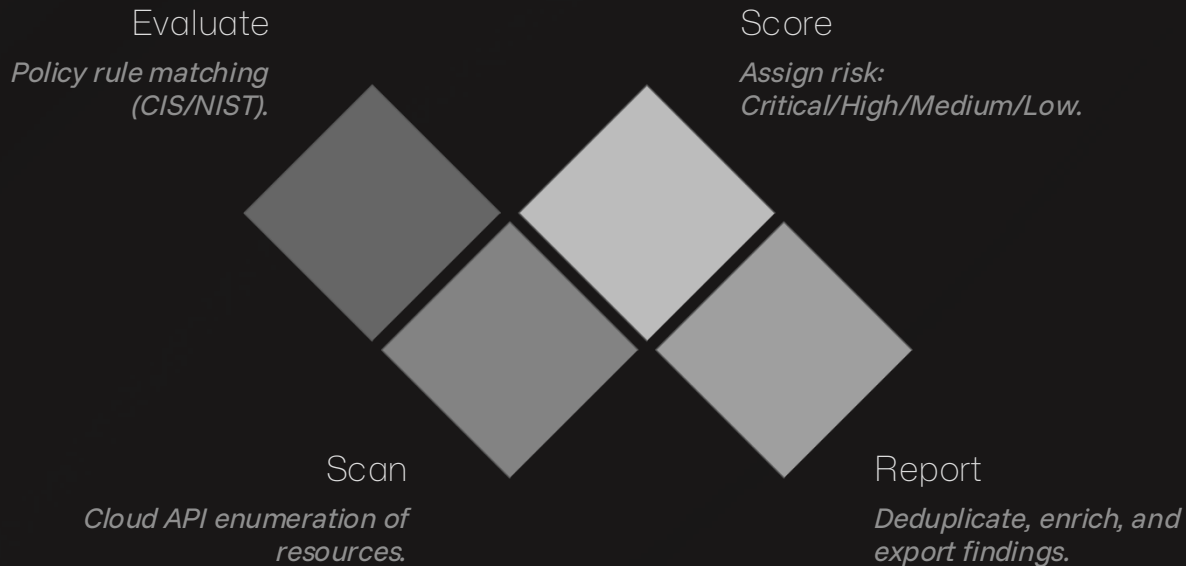
*AWS Security Hub · Azure Defender · CSPM connectors · OPA (Open Policy Agent)*



## Frontend & Observability

*React · Grafana · Prometheus · OpenTelemetry tracing*

# Security Findings Engine



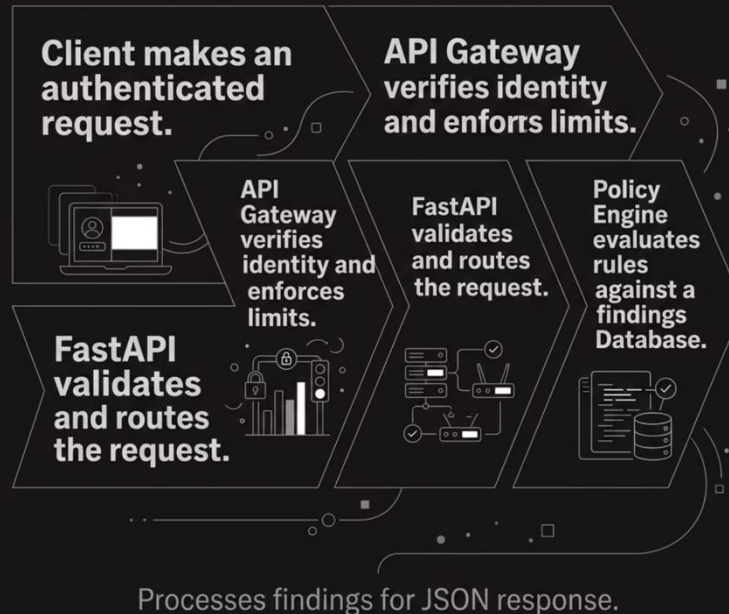
*The engine evaluates every cloud resource against a versioned policy library. Findings are deduplicated across scans, enriched with asset context, and assigned a composite risk score combining severity, exposure, and regulatory impact.*

# API Architecture

## RESTful Design

- **GET /findings** — filterable, paginated findings export
- **POST /scan** — trigger on-demand audit scan
- **GET /compliance/{framework}** — framework-specific posture report
- **POST /policies** — upload custom guardrail rules

 All endpoints are authenticated via OAuth2 with RBAC scopes. Audit logs are immutable and WORM-compliant.





# Dashboard & Data Model

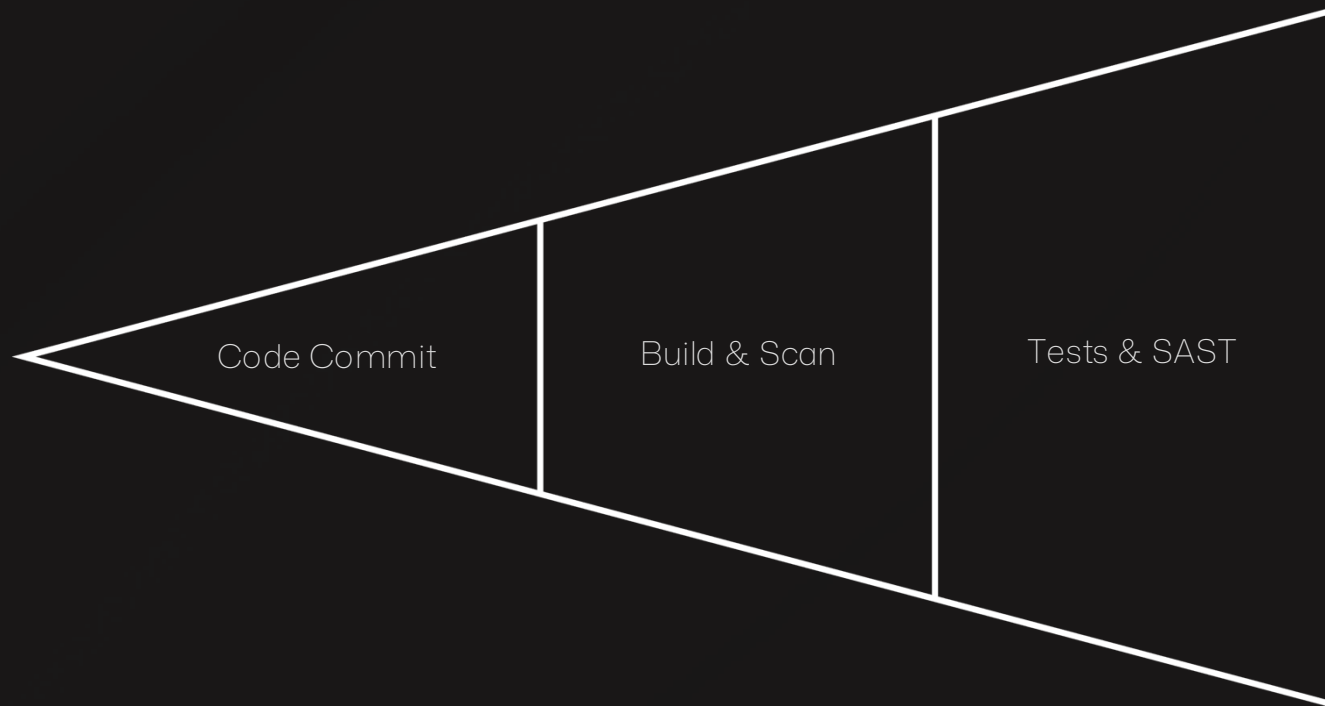


## Core Schema Entities

- **assets** — cloud resource inventory (ARN, region, tags)
- **findings** — deduplicated violation records with severity scores
- **policies** — versioned rule definitions (CIS, NIST, custom)
- **scans** — execution metadata, timestamps, status
- **remediations** — ticket linkage, resolution state, SLA tracking

Schema supports multi-tenant isolation and point-in-time audit reconstruction.

# CI/CD Pipeline



*Every policy change and engine update flows through a gated pipeline. Security scanning is embedded at two stages — SAST on source code and container vulnerability scanning post-build — ensuring no regression reaches production.*



# Demo Walkthrough

01

---

## Trigger Scan

*Initiate on-demand audit against a target AWS account via API or UI.*

03

---

## Export Compliance Report

*Generate ISO 27001 or SOC 2 aligned report — PDF or structured JSON — for auditors.*

02

---

## Review Findings

*Dashboard surfaces Critical/High findings with resource context, policy reference, and remediation steps.*

04

---

## Track Remediation

*Findings link to Jira tickets; SLA countdown and resolution status tracked automatically.*

# Impact, Learnings & Roadmap

## Business Impact

*Estimated 70% reduction in manual audit effort. Continuous compliance posture replaces point-in-time reviews.*

## Key Learnings

*Policy-as-code adoption requires stakeholder alignment early. Deduplication logic is critical to avoid alert fatigue.*

## Challenges Faced

*Multi-cloud API inconsistency, false-positive tuning, and scaling scan concurrency under rate limits.*

## Future Improvements

*AI-assisted remediation suggestions, auto-remediation via Terraform, and GRC platform integration (ServiceNow, Archer).*

